

# Credential Stuffing Attack response

Intrusion · **High** severity · SOC IR Playbook

|                   |                                                                                                                |
|-------------------|----------------------------------------------------------------------------------------------------------------|
| Incident type     | Account Takeover via Credential Abuse                                                                          |
| Severity          | High                                                                                                           |
| Priority          | High                                                                                                           |
| Detection sources | SIEM, IAM logs, WAF, fraud detection systems, application logs, CDN security layers (e.g., Cloudflare, Akamai) |

## Scenario

An attacker uses automated tools and botnets to test large volumes of stolen credentials (typically from dark web breaches) against a login portal in hopes of reusing valid username-password combinations. This can lead to unauthorised access to user accounts and potential data theft or fraud.

## MITRE ATT&CK

T1078, T1110.001, T1589.001, T1589.002

## Preparation

Enforce MFA Strongest defence against credential reuse Rate limit login attempts Use WAF/CDN or application-level throttling Monitor for credential stuffing patterns Spike in failed logins, login attempts from multiple geographies Use CAPTCHA or bot protection Block automated tools Subscribe to credential breach feeds Integrate with HaveIBeenPwned, SpyCloud or similar sources

## Detection & Analysis

Identify unusual login activity Multiple failed attempts across many usernames from same IP Review IAM and app logs Track login frequency, IPs, device fingerprints, user agents Check for bot behaviour Impossible travel, excessive logins within a time window, sequential patterns Validate account takeovers Determine if login succeeded with breached credentials

## Containment

Block IPs or IP ranges Use WAF, CDN or firewall to block offending sources Trigger forced password resets For impacted users whose credentials were reused Throttle traffic Apply tighter rate limits or geo-blocking rules temporarily Suspend affected sessions Invalidate active sessions and tokens for suspected accounts

## Eradication

Remove test accounts or injected data If attacker created new users or added persistent artefacts Patch login abuse vectors Harden login flow, disable username enumeration, limit error messaging Enforce stronger passwords Update password policies if weak credentials are in use Enhance detection rules Fine-tune alerting thresholds and response automation for credential stuffing attempts

## Recovery

Notify users Alert affected users about forced resets and possible compromise Monitor for repeated attempts Continue enhanced monitoring for 24-72 hours Re-enable access Once accounts are secured with MFA and/or new credentials Review and test controls Ensure rate limiting, MFA enforcement and logging mechanisms are effective

## Lessons Learned & Reporting

Conduct root cause analysis Was a specific API, endpoint or weak control abused? Document affected users and accounts Tally successful logins from malicious sources Report to regulators If account takeover results in breach of personal or financial data Update security controls Apply geo-fencing, browser fingerprinting, CAPTCHA and bot mitigation tools Improve user communication Provide guidance on password hygiene and breach alert follow-ups

### ***Tools typically involved***

WAF/CDN (e.g., Cloudflare, Akamai, AWS WAF); IAM logs and systems (e.g., Azure AD, Okta, AWS Cognito); SIEM (e.g., Sentinel, Splunk); Bot detection services (e.g., reCAPTCHA, PerimeterX, Cloudflare Bot Management); Breach monitoring platforms (e.g., SpyCloud, HaveIBeenPwned); Threat intelligence platforms (e.g., Recorded Future, MISP)

### ***Success metrics (SLA targets)***

Detection Time <5 minutes from surge in login attempts Containment Time <30 minutes from attack confirmation User Impact Mitigation Time <2 hours for forced resets and notifications Recurrence Rate Zero re-use after controls applied Post-Attack Monitoring Period Minimum 7-14 days for affected systems or portals